Enumerating Entra ID Anonymously

trimarcsecurity.com/hub-post/enumerating-entra-id-anonymously

Brandon Colley October 30, 2023

Updated: Dec 13, 2024

Introduction

Enumeration, also referred to as reconnaissance, is identified as the first step in the Cyber Kill Chain. This phase includes researching a target to identify vulnerabilities, weak spots, and possible entry points. In many cases this phase goes completely unnoticed by the target. A carefully organized reconnaissance phase may allow for a swift and nimble attack leaving the target wondering what happened.

An enterprise's ability to know what attackers can discover helps them better protect what can be protected and be better prepared for the things they cannot. Preparing Active Directory (AD) for reconnaissance can be like preparing your home before going on vacation.

· Did you lock the doors so a burglar can’t just walk in?

· Were the windows closed so a burglar couldn’t climb in the second story window?

· Are the shades drawn to hide that brand new big-screen TV?

· Can you really trust your neighbor’s teenage daughter to feed the cats?

What are you really worried about anyway? You live in a nice quiet neighborhood. Someone would need to drive past all your neighbors before even getting on premises.

Now what happens when you move to the cloud where everyone is a close neighbor… even the burglars?

Of course, we aren’t talking about your home anymore. While your on-prem AD home isn’t the same as your vacation Entra ID home, the metaphor still holds true. Attackers are peeking through your Windows ™ looking for points of entry.

Featured Tools

Entra ID / Azure AD enumeration is not a new idea. Microsoft can change the name, but these techniques continue to persist. There have been a number of enumeration tools dating back to the inception of Azure AD all leveraging different techniques to perform similar reconnaissance techniques. Two of the most modern and up to date tools are AADInternals and OneDrive User Enum. Both tools were showcased this year at DEFCON 31.

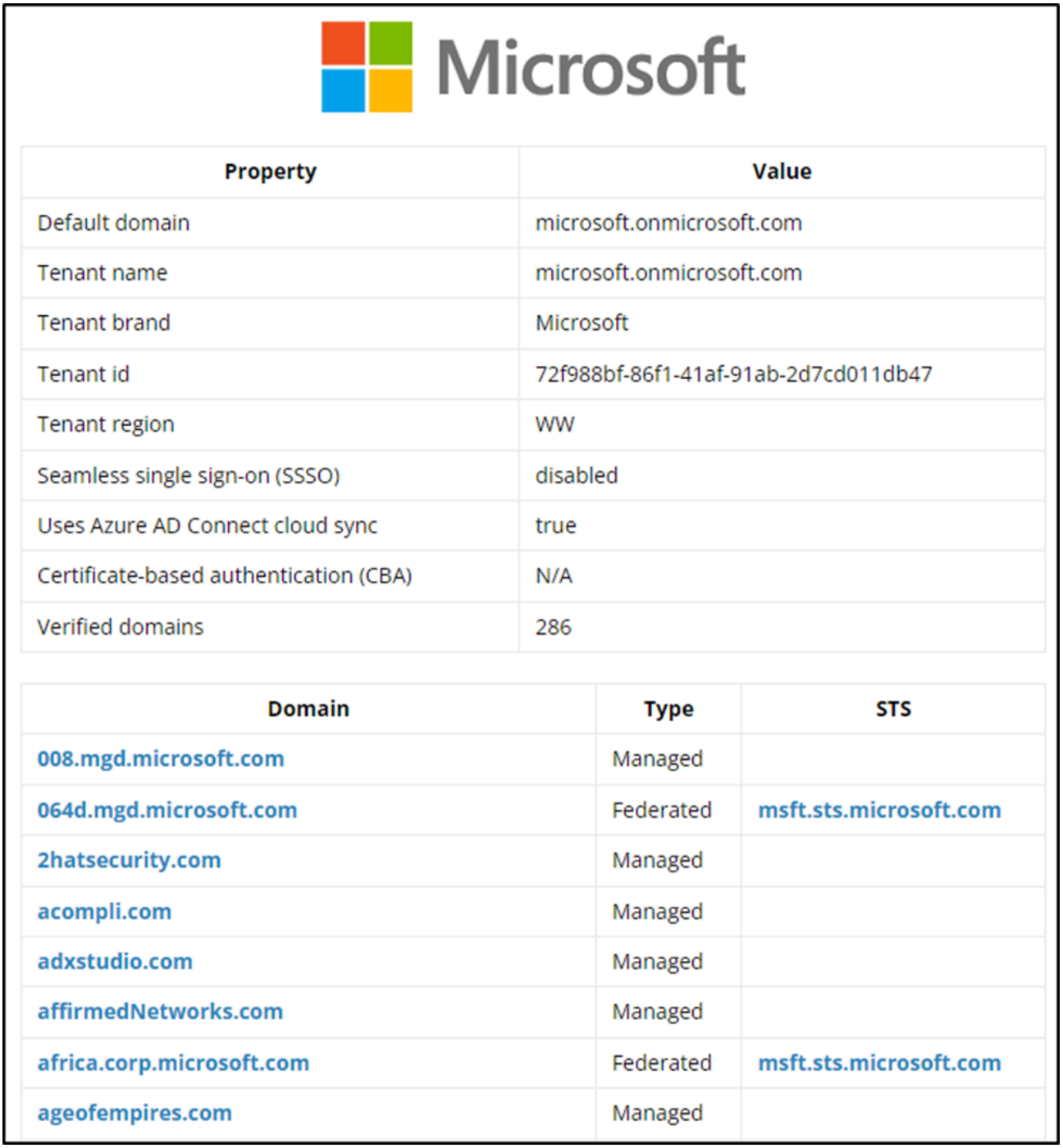
AADInternals is written and maintained by Dr. Nestori Syynimaa (@DrAzureAD). Dr. Syynimaa has provided nearly 5 years of consistent updates to the tool and has made countless contributions to the community earning him a Microsoft MVP and landing him on Microsoft's Most Valuable Security Researcher (MVR) list. In addition to the GitHub repository linked above, Dr. Syynimaa has made a free online version of his tooling available.

OneDrive User Enum is written and released by @nyxgeek. This tool is the newest iteration of Azure AD User Enumeration which leverages the default OneDrive URL created for each user upon activation. An outline and demonstration of the tool is published on the TrustedSec blog.

This article digs into these tools to see what information is available and why it matters. First up, tenant configuration details.

Tenant Configuration

Knowledge of only a domain name or email address in a target tenant reveals several configuration details you may have not known were publicly available. First is a list of all associated domain names. Depending on the tenant this may not be terribly interesting but for larger companies with multiple mergers and acquisitions, the domain list can easily enter the hundreds. This may be helpful for an attacker to identify a parent tenant for an associated domain or could provide a list of potential domains to include in an attack. Each domain also divulges its authentication type as either Managed or Federated. If federated, a link to the federated server is provided.



Microsoft

Property	Value
Default domain	microsoft.onmicrosoft.com
Tenant name	microsoft.onmicrosoft.com
Tenant brand	Microsoft
Tenant id	72f988bf-86f1-41af-91ab-2d7cd011db47
Tenant region	WW
Seamless single sign-on (SSSO)	disabled
Uses Azure AD Connect cloud sync	true
Certificate-based authentication (CBA)	N/A
Verified domains	286

Domain	Type	STS
008.mgd.microsoft.com	Managed	
064d.mgd.microsoft.com	Federated	msft.sts.microsoft.com
2hatsecurity.com	Managed	
acompli.com	Managed	
adxstudio.com	Managed	
affirmedNetworks.com	Managed	
africa.corp.microsoft.com	Federated	msft.sts.microsoft.com
ageofempires.com	Managed	

The AADInternals PowerShell modules provide even more details for each domain. DNS data is used to infer the usage of email by listing DNS, MX, SPF, and DMARC records. The existence of MX and DMARC records indicates the domain accepts email and the implementation of an SPF record identifies that the domain may be used to send email. Among other things, this information may be valuable when initiating a phishing campaign. An understanding of domains and their use can provide an attacker with a list of domains to target and/or spoof as the sender address.

```
PS C:\Users\Me> Invoke-AADIntReconAsOutsider -DomainName microsoft.com | ft
Tenant brand:       Microsoft
Tenant name:        microsoft.onmicrosoft.com
Tenant id:          72f988bf-86f1-41af-91ab-2d7cd011db47
Tenant region:      WW
DesktopSSO enabled: False
Uses cloud sync:    True

Name                                    DNS    MX   SPF DMARC Type      STS
----                                    ---    --   --- ----- ----      ---
008.mgd.microsoft.com                 False False False       Managed
064d.mgd.microsoft.com                False False False       Federated msft.sts.microsoft.com
2hatsecurity.com                       True  True  True False Managed
acompli.com                            True  True  True True  Managed
adxstudio.com                          True  True  True True  Managed
affirmedNetworks.com                   True  True  True True  Managed
africa.corp.microsoft.com             False False False True  Federated msft.sts.microsoft.com
ageofempires.com                       True False  True True  Managed
```

The AADInternals PowerShell module also searches for the existence of the Microsoft Defender for Identity (MDI) instance. This information provides an attacker knowledge of what they may be up against in terms of threat protection. These screenshots offer an attacker other useful information that identifies how on-prem Active Directory is integrated and how authentication is configured.

Implementation of Seamless Single Sign-On (SSSO), Azure AD Connect cloud sync, and Certificate-based authentication (CBA) can be easily discovered. Each of these configurations have their own unique attack strategies and provide an attacker with the blueprint required to formulate the specific attack path for the tenant.

The last pieces of information that are freely available may appear to be the most boring. In actuality, they could be the most sensitive of all aforementioned data. The tenant name, ID, and region are all required when performing certain API calls against a tenant. Using this discovered data and Microsoft APIs, it is possible to gain even more tenant information in preparation for Phase 2 of the enumeration journey.

User Enumeration

With knowledge of the tenant now in hand, it is possible to begin enumerating users associated with the tenant. When provided a username, this AADInternals command will determine if the user exists.

```
PS C:\Users\administrator> Invoke-AADIntUserEnumerationAsOutsider -UserName Brandon.Colley@[redacted].onmicrosoft.com

UserName                          Exists
--------                          ------
Brandon.Colley@[redacted].onmicrosoft.com   True


PS C:\Users\administrator> Invoke-AADIntUserEnumerationAsOutsider -UserName BColley@[redacted].onmicrosoft.com

UserName                    Exists
--------                    ------
BColley@[redacted].onmicrosoft.com  False
```

Better yet, it supports passing a file full of possible usernames. Microsoft throttled me while using this method during testing so we enlisted some help from other domains.

```
PS C:\Windows\System32> Get-Content .\emails.txt | Invoke-AADIntUserEnumerationAsOutsider

WARNING: Requests throttled!
UserName                                Exists
--------                                ------
brandon.colley@[redacted].onmicrosoft.com   True
bcolley@[redacted].onmicrosoft.com         False
brandon.colley@microsoft.com
bcolley@[redacted].com                     False
WARNING: Requests throttled!
jjohnson@microsoft.com
WARNING: Requests throttled!
dsmith@microsoft.com
WARNING: Requests throttled!
akhan@microsoft.com
kevin.smith@[redacted].com                 False
brandon.colley@[redacted].com              False
akumar@[redacted].com                      False
jameswilliams@[redacted].com                True
david.johnson@[redacted].com                True
brandon.colley@[redacted].com              False
chris.brown@[redacted].com                 False
```

AADInternals is built to support three methods that enumerate accounts: GetCredentialType, Autologon, and a standard login attempt. Actual login attempts would be logged to the tenant's sign-in log but when using the autologon method there are no logs and is therefore undetectable to the tenant.

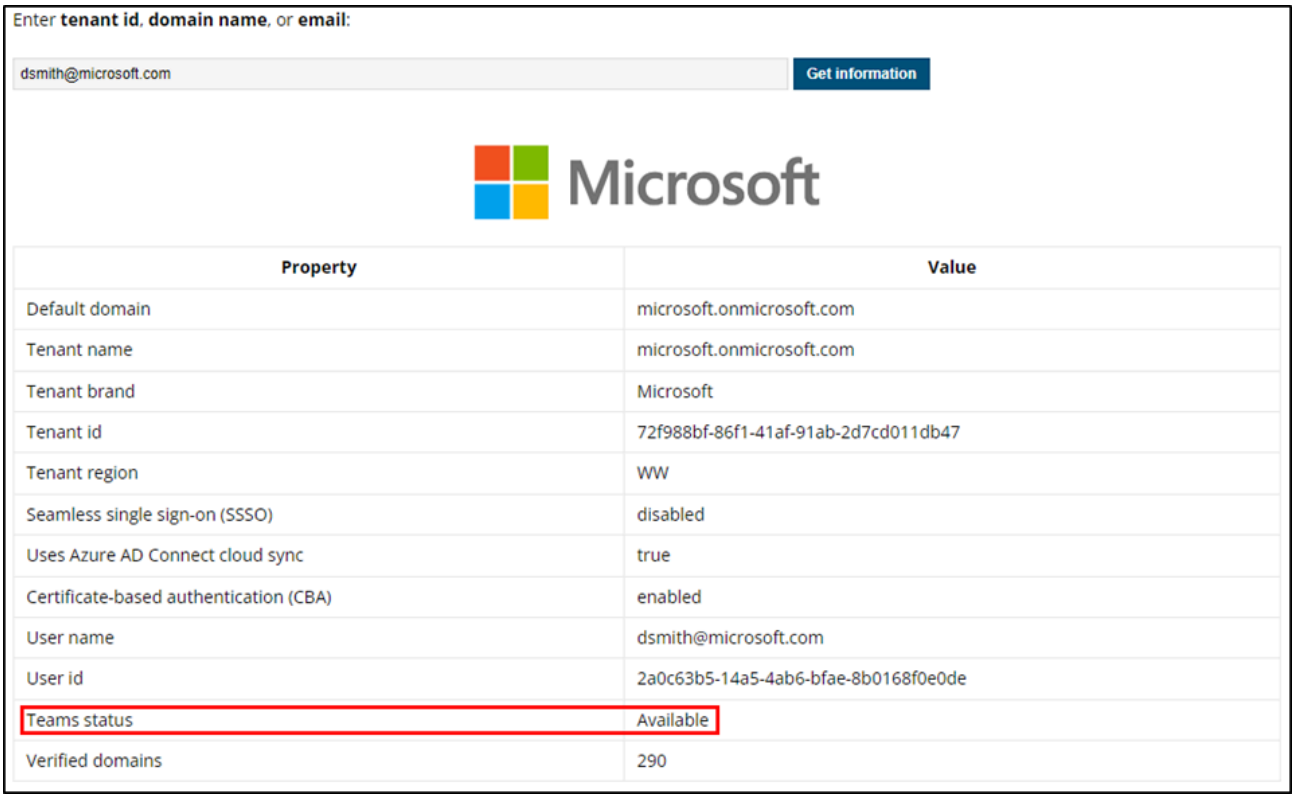
Another stealthy method is to use OneDrive for user enumeration. Using a similar user list, OneDrive Enumerator identified valid usernames and was not throttled.

```
Beginning enumeration of https://microsoft-my.sharepoint.com/personal/USER_microsoft_com/
-------------------------------------------------------------------------------------------------
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - johns, username:johns@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - kumars, username:kumars@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - davids, username:davids@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - jsmith, username:jsmith@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - johnm, username:johnm@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - davidsmith, username:davidsmith@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - mike, username:mike@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - khans, username:khans@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - arunkumar, username:arunkumar@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - davidm, username:davidm@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - smithc, username:smithc@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - msmith, username:msmith@microsoft.com
[-] [403] VALID USERNAME FOR microsoft,microsoft.com - michaels, username:michaels@microsoft.com
```

The above examples only used a small list of possible usernames but the methodology scales into the several thousands.

Given enough time and dedication, this enumeration method effectively enables an attacker to anonymously identify all usernames associated with a tenant. The knowledge of valid email addresses associated with a tenant allows for targeted password attacks or phishing techniques like the ones outlined in Dr. Syynimaa's blog.

The information gained so far also allows anonymous access to Teams information. The AADInternals OSINT tool leverages yet another API call to request Teams status when searching on an email.



Property	Value
Default domain	microsoft.onmicrosoft.com
Tenant name	microsoft.onmicrosoft.com
Tenant brand	Microsoft
Tenant id	72f988bf-86f1-41af-91ab-2d7cd011db47
Tenant region	WW
Seamless single sign-on (SSSO)	disabled
Uses Azure AD Connect cloud sync	true
Certificate-based authentication (CBA)	enabled
User name	dsmith@microsoft.com
User id	2a0c63b5-14a5-4ab6-bfae-8b0168f0e0de
Teams status	Available
Verified domains	290

Teams presence was part of nyxgeek's DEFCON 30 talk, "Track The Planet". This talk introduced an unauthenticated method to report on Teams status. Nyxgeek demonstrated the true impact of enumeration by tracking thousands of users across multiple months. This resulted in a heat map that easily identified common working hours, shared meetings, and observed holidays.

This is one of many methods used to abuse user enumeration and to steal my favorite meme from nyxgeek's DEFCON talk.



Mitigations

As the meme suggests, Microsoft has taken the official stance that enumeration is not a bug. That's not to say they have no cultural awareness because in the days following DEFCON, Microsoft silently patched an anonymous method of Teams status enumeration. Unfortunately, as time has taught us, whenever one method is stopped, two more rise from the ashes. While truly anonymous methods of enumeration were patched, any licensed account can still perform Teams presence lookups.

With that said, there is hope. External Teams access can be limited to prevent these enumeration techniques. Microsoft documentation outlines the available options. Every tenant should evaluate which configuration makes sense for their organization.

There are methods to disable OneDrive sites but this may break existing operating procedures. It also relies upon cleaning up all sites for existing users. As mentioned previously, OneDrive enumeration is just one of many methods to perform user enumeration.

In his article, nyxgeek offers his best solution. Using a pseudo-random username format can make enumeration much more difficult. "By adding six (6) digits to the end of a normal 'jsmith' username, you increase the enumeration resistance by a million. An attacker would then need to iterate through A MILLION attempts just to get any 'jsmith' matches. "

Sometimes having the knowledge of what's possible helps put things in perspective and aids in preparation. Returning to the home security analogy, when you know where your

points of entry are, you know how to protect yourself. You put a camera out front, flood lights on the garage, and motion alarms near the picture windows. If someone breaches the parameter, you'll know, and...

